| ID | Part | Topic | Requirement (Annex I, verbatim) | Applicable | Justification for Applicability | Affected components in the System Context | How Fulfilled | Evidence for Fulfillment | Verdict | Conflicts / notes |
|---|---|---|---|---|---|---|---|---|---|---|
| **I(1)** | Part I | Appropriate level of cybersecurity | Products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks. | Yes | FinSec verarbeitet sensible Finanzdaten und ermöglicht Zahlungsaufträge. Das Sicherheitsniveau muss zu diesen Risiken passen. | Web-Frontend (C02), Mobile App (geplant) (C03), Anwendungslogik (C04), Finanzdatenverarbeitung (C05), Bankanbindung (C06), Datenbank (C07) | | | | |
| **I(2)(a)** | Part I | No known exploitable vulnerabilities | be made available on the market without known exploitable vulnerabilities; | Yes | Bekannte ausnutzbare Schwachstellen könnten Kontodaten und Zahlungsfunktionen gefährden und müssen vor der Veröffentlichung behoben werden. | Web-Frontend (C02), Mobile App (geplant) (C03), Anwendungslogik (C04), Finanzdatenverarbeitung (C05), Bankanbindung (C06), Datenbank (C07) | | | | |
| **I(2)(b)** | Part I | Secure by default configuration | be made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the possibility to reset the product to its original state; | Yes | Nutzer sollen FinSec von Anfang an sicher verwenden können, ohne selbst Sicherheitseinstellungen anpassen zu müssen. | Web-Frontend (C02), Mobile App (geplant) (C03), Anwendungslogik (C04), Finanzdatenverarbeitung (C05), Bankanbindung (C06), Datenbank (C07) | | | | |
| **I(2)(c)** | Part I | Security updates | ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them; | Yes | In FinSec und seinen Bibliotheken können neue Schwachstellen entdeckt werden, die durch Sicherheitsupdates behoben werden müssen. | Web-Frontend (C02), Mobile App (geplant) (C03), Anwendungslogik (C04), Finanzdatenverarbeitung (C05), Bankanbindung (C06), Datenbank (C07) | | | | |
| **I(2)(d)** | Part I | Protection from unauthorised access | ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible unauthorised access; | Yes | Nur berechtigte Nutzer dürfen auf ihre Kontodaten zugreifen und Zahlungsaufträge auslösen. | Web-Frontend (C02), Mobile App (geplant) (C03), Anwendungslogik (C04), Bankanbindung (C06), Datenbank (C07) | | | | |
| **I(2)(e)** | Part I | Confidentiality | protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by state of the art mechanisms, and by using other technical means; | Yes | Persönliche Informationen und Kontodaten müssen bei Speicherung, Übertragung und Verarbeitung vor unberechtigtem Mitlesen geschützt werden. | Web-Frontend (C02), Mobile App (geplant) (C03), Anwendungslogik (C04), Finanzdatenverarbeitung (C05), Bankanbindung (C06), Datenbank (C07) | fd | dfdf | dfd | dfd |
| **I(2)(f)** | Part I | Integrity | protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions; | Yes | Kontodaten und Zahlungsaufträge dürfen nicht unberechtigt verändert werden, insbesondere Betrag und Empfänger einer Überweisung. | Web-Frontend (C02), Mobile App (geplant) (C03), Anwendungslogik (C04), Finanzdatenverarbeitung (C05), Bankanbindung (C06), Datenbank (C07) | | | | |
| **I(2)(g)** | Part I | Data minimisation | process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimisation); | Yes | FinSec soll nur die Nutzer- und Finanzdaten verarbeiten, die für die angebotenen Funktionen benötigt werden. | Web-Frontend (C02), Mobile App (geplant) (C03), Anwendungslogik (C04), Finanzdatenverarbeitung (C05), Bankanbindung (C06), Datenbank (C07) | | | | |
| **I(2)(h)** | Part I | Availability / DoS resilience | protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks; | Yes | Kontoübersicht und Zahlungsfunktionen sollen auch bei hoher Last oder Angriffen möglichst verfügbar bleiben. | Web-Frontend (C02), Mobile App (geplant) (C03), Anwendungslogik (C04), Finanzdatenverarbeitung (C05), Bankanbindung (C06), Datenbank (C07) | | | | |
| **I(2)(i)** | Part I | Minimise impact on other services | minimise the negative impact by the products themselves or connected devices on the availability of services provided by other devices or networks; | Yes | Fehlerhafte oder übermäßig häufige Anfragen von FinSec dürfen angebundene Bankdienste und andere Systeme nicht unnötig belasten. | Web-Frontend (C02), Mobile App (geplant) (C03), Anwendungslogik (C04), Finanzdatenverarbeitung (C05), Bankanbindung (C06), Datenbank (C07) | | | | |
| **I(2)(j)** | Part I | Limit attack surface | be designed, developed and produced to limit attack surfaces, including external interfaces; | Yes | FinSec soll nur benötigte Schnittstellen und Funktionen bereitstellen, um mögliche Angriffspunkte zu begrenzen. | Web-Frontend (C02), Mobile App (geplant) (C03), Anwendungslogik (C04), Finanzdatenverarbeitung (C05), Bankanbindung (C06), Datenbank (C07) | | | | |

| | | | | | | | | | | |
|---|---|---|---|---|---|---|---|---|---|---|
| **I(2)(k)** | Part I | Exploitation mitigation | be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques; | Yes | Wird ein Teil von FinSec angegriffen, sollen eingeschränkte Rechte und getrennte Bereiche den möglichen Schaden begrenzen. | Web-Frontend (C02), Mobile App (geplant) (C03), Anwendungslogik (C04), Finanzdatenverarbeitung (C05), Bankanbindung (C06), Datenbank (C07) | | | | |
| **I(2)(l)** | Part I | Security logging and monitoring | provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user; | Yes | Verdächtige Zugriffe und sicherheitsrelevante Änderungen müssen erkennbar sein, damit auf mögliche Angriffe reagiert werden kann. | Web-Frontend (C02), Mobile App (geplant) (C03), Anwendungslogik (C04), Finanzdatenverarbeitung (C05), Bankanbindung (C06), Datenbank (C07) | | | | |
| **I(2)(m)** | Part I | Secure data removal and transfer | provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner. | Yes | Nutzer sollen ihre Daten und Einstellungen sicher löschen und, soweit eine Übertragung angeboten wird, sicher übertragen können. Gesetzliche Aufbewahrungspflichten sind dabei zu beachten. | Web-Frontend (C02), Mobile App (geplant) (C03), Anwendungslogik (C04), Finanzdatenverarbeitung (C05), Bankanbindung (C06), Datenbank (C07) | | | | |

**Summary**

| | | |
|---|---|---|
| **PASS** | | **0** |
| **FAIL** | | **0** |
| **N/A** | | **0** |
| **Not yet assessed** | | **13** |
| **N/A without justification** | | **0** |
| **Overall verdict** | | **INCOMPLETE** |